1.3.4 Heightened regulatory environment

Regulatory compliance is yet another reason why authorization is increasingly important. Most organizations are subject to numerous regulations that dictate the access requirements for many kinds of data.

Some regulations require that employee access be sensitive to context. For example, the Health Insurance Portability and Accountability Act (HIPAA) mandates that access to patient data be limited to those who need it for purposes of treatment, payment, or facility operations. For example, a nurse's access to patient records might be limited to those patients under her care while she's on duty.

Some regulations require that employees have the minimal access needed to do their jobs—the *principle of least privilege*. For example, to comply with the provisions of SOX, a company may need to ensure that a financial analyst has access only to financial reports and not the raw data that underlies them. Dynamic authorization based on policy can make fine-grained access control decisions based on the analyst's role or other attributes.

Compliance with regulations might depend on attributes of the person making the request as well as the attributes of the data. For example, the General Data Protection Regulation (GDPR) requires that access to personal information depend on the person's consent. Policies can be written to use both the attributes of the data and those of the person making the request.

Compounding the problems of compliance, regulations change frequently, requiring updates to the access control systems that enforce them. Dynamic authorization through policy allows organizations to more easily update access protections in response to changing regulations.

Finally, most regulations require auditing to ensure compliance. Dynamic authorization systems have provisions for access logging that make conducting audits easier. In contrast, homegrown systems must build logging into the system.